RSUD R.A.A. TJOKRONEGORO PURWOREJO

LAPORAN HASIL TESTING & SECURITY AUDIT — SAPA RSTN

QA & SECURITY AUDIT

Tanggal: 21 Oktober 2026 | **Target:** Portal Pasien (Frontend Vue 3 + Vite) | **Lingkungan:** Vitest, Node.js v24, JSDOM

1. Ringkasan Eksekutif

Pengujian otomatis dan audit keamanan aplikasi web **SAPA RSTN** (Sistem Aplikasi Pasien RSUD R.A.A. Tjokronegoro) telah diselesaikan dalam satu siklus terpadu (*single-run*). Seluruh dependensi pengujian dijalankan pada lingkungan terisolasi dengan mock API lengkap tanpa memanggil jaringan eksternal dan tanpa mengakses data riil pasien.

140 / 140	0	SUKSES	12
KASUS UJI LULUS (100%)	KASUS UJI GAGAL	BUILD PRODUKSI (1.93S)	KERENTANAN DEP. (NPM AUDIT)

Tiga Temuan Utama yang Membutuhkan Atensi Tim:

1. **[Keamanan - Tinggi] Potensi Stored XSS via `v-html` di Edukasi Kesehatan:** Field `artikel.isi` dirender tanpa sanitasi HTML sisi klien (belum memakai `DOMPurify`). Rentan jika backend mengembalikan script berbahaya.
2. **[Keamanan - Sedang] Reverse Tabnabbing pada Pratinjau Dokumen PDF iOS:** Pemanggilan `window.open(url, '_blank')` tidak menyertakan `'noopener,noreferrer'`.
3. **[Keamanan & Kompatibilitas - Sedang] Mixed Content Risk pada Gambar Edukasi:** Base URL gambar didefinisikan dengan protokol HTTP mentah ke alamat IP publik (`http://194.169.46.193/...`) alih-alih domain HTTPS resmi.

2. Tabel Hasil Pengujian per Area

Area	Cakupan Pengujian	Target File / Modul	Jumlah Test	Status
Area A: Fondasi	Auth Store, Axios API interceptor (Bearer & 401 redirect), Navigation Guards, dan route registration.	`src/services/api.js` `src/stores/auth.js` `src/router/index.js`	20 Test	20 LULUS (100%)
Area B: Tagihan Pasien Umum	Resolusi status (kunci vs final), kalkulasi subtotal/total, variasi spasi/kapitalisasi, state loading/empty/error.	`src/views/TagihanPasienUmumView.vue`	24 Test	24 LULUS (100%)
Area C: Notifikasi	Store personal vs blast, unread counter badge, mark-as-read resilience, proteksi skema URL (tolak javascript:/data:).	`src/stores/notification.js` `src/utils/notifTarget.js` `src/components/common/Notification*.vue`	35 Test	35 LULUS (100%)

Area	Cakupan Pengujian	Target File / Modul	Jumlah Test	Status

Area D: Edukasi Kesehatan	Parsing tag string, filter chip multi-tag, counter API tepat 1x (resilien saat error), URL fallback image.	`src/utils/edukasi.js`
		`src/views/EdukasiView.vue`
		`src/views/EdukasiDetailView.vue`
			36 Test	**36 LULUS (100%)**

Area E: Rencana Kontrol BPJS	Parsing payload kontrol, format jam HH:mm, pemisahan tegas state "tidak ada data" vs "gagal memuat", retry fetch.	`src/views/RiwayatReservasiView.vue`	25 Test	**25 LULUS (100%)**

3. Daftar Temuan Terperinci (Security & Functional Findings)

A. Temuan Keamanan (Security Vulnerabilities)

TINGGI **SEC-01: Potensi Stored XSS via Direktif v-html pada Artikel Edukasi** `EdukasiDetailView.vue:L91`

Konten artikel kesehatan dirender langsung menggunakan `v-html="artikel.isi || 'Belum ada konten'"`. Jika data API dari backend atau database disusupi payload HTML berbahaya (misal `<img src=x onerror=...>`), kode JavaScript tak berizin akan tereksekusi di browser pasien dengan hak akses penuh ke LocalStorage portal.

> **Rekomendasi Perbaikan:** Pasang pustaka `dompurify` dan bungkus sebelum dirender: `const cleanContent = computed(() => DOMPurify.sanitize(artikel.value?.isi || ''))`.

SEDANG **SEC-02: Reverse Tabnabbing via window.open Tanpa noopener,noreferrer** `PreviewDokumenView.vue:L279`

Pada penanganan unduh PDF untuk perangkat iOS, tab baru dibuka dengan `window.open(url, '_blank')` tanpa parameter rel. Halaman yang dibuka memiliki akses ke `window.opener` dan berpotensi memanipulasi tab asal pasien.

> **Rekomendasi Perbaikan:** Gunakan parameter ketiga: `window.open(url, '_blank', 'noopener,noreferrer')`.

SEDANG **SEC-03: Hardcoded Base URL Gambar Menggunakan Plain HTTP dan IP Publik** `src/utils/edukasi.js:L8`

Base URL didefinisikan sebagai `http://194.169.46.193/gos2_plus/uploads/edukasi/`. Saat portal di-hosting pada HTTPS, peramban modern akan memblokir gambar tersebut akibat *Mixed Content Policy*, serta mengekspos IP server internal.

> **Rekomendasi Perbaikan:** Pindahkan ke environment variable `import.meta.env.VITE_EDUKASI_IMG_BASE` dengan fallback domain resmi `https://apirstjokro.purworejokab.go.id/...`.

SEDANG **SEC-04: Kredensial Firebase Client Hardcoded dalam Source Code** `src/services/firebase.js:L5-13`

Kredensial Firebase (API Key, Project ID, App ID) tercantum statis di source code. Meskipun client-side config, best practice mewajibkan isolasi melalui variabel `.env` dan pembatasan domain di Google Cloud Console.

> **Rekomendasi Perbaikan:** Gunakan `import.meta.env.VITE_FIREBASE_*` dan aktifkan HTTP Referrer Restrictions pada API Key.

TINGGI **SEC-05: 12 Kerentanan Tingkat Tinggi pada Dependensi Pihak Ketiga** `package.json (NPM Audit)`

Audit dependensi menemukan 12 vulnerabilitas tingkat High pada paket `@grpc/grpc-js` (auth cert bypass), `@vue/server-renderer` (XSS), `fast-uri` (SSRF), `follow-redirects` (credential leak), `source-map-js` (DoS), dan `vite/launch-editor` (command execution).

> **Rekomendasi Perbaikan:** Lakukan koordinasi pembaruan minor/patch pada Vite (>=8.2.3) dan patch paket Firebase.

RENDAH **SEC-06: Penyimpanan Token JWT dan Data Pasien Sensitif di LocalStorage** `src/stores/auth.js:L35-36`

`sapa_token` dan objek `sapa_user` (berisi NORM dan nama pasien) disimpan dalam LocalStorage yang rentan diekfiltrasi jika terjadi serangan XSS pada aplikasi.

> **Rekomendasi Perbaikan:** Evaluasi penggunaan cookie `HttpOnly; Secure; SameSite=Strict` untuk token sesi.

B. Temuan Fungsional & Arsitektur

SEDANG **FUNC-01: Fitur Tandai Semua Dibaca Belum Terhubung ke Endpoint Server** `src/stores/notification.js:L276`

Fungsi `markAllPersonalAsRead()` hanya menandai status baca pada LocalStorage lokal browser tanpa mengirimkan request sinkronisasi ke server API SIMRS. Status unread akan muncul kembali bila pasien membuka perangkat lain.

> **Rekomendasi:** Koordinasikan dengan backend untuk penyediaan endpoint `POST /notifikasi/tandai-semua-dibaca`.

SEDANG **FUNC-02: Inkonsistensi Dokumentasi Respons Rencana Kontrol BPJS Saat Nihil** `src/views/RiwayatReservasiView.vue:L692`

Bentuk payload SIMRS saat pasien tidak memiliki rencana kontrol belum didokumentasikan secara definitif (apakah `data: null`, `data: []`, atau kode HTTP selain 200).

> **Rekomendasi:** Tetapkan kontrak API JSON formal dengan mentor SIMRS untuk skenario data kosong.

4. Hasil Pemeriksaan Statis & Keamanan

Parameter Pemeriksaan	Kondisi / Nilai	Analisis & Evaluasi
Build Produksi Vite	SUKSES (1.93S)	Bundle teroptimasi bersih (446 KB preview chunk, 166 KB core index). PWA SW ter-generate.
Esbuild Console Drop	AKTIF	Seluruh `console.log` dan `debugger` otomatis dihilangkan pada bundle produksi.
PWA Service Worker Caching	AMAN	Runtime caching **hanya** menyasar font Google. Endpoint API data medis tidak di-cache di SW.
Penggunaan innerHTML / eval	NIHIL (0)	Tidak ditemukan penggunaan `eval()`, `new Function()`, atau `innerHTML` langsung.
Content Security Policy (CSP)	BELUM TERPASANG	File `index.html` belum memuat meta tag CSP atau Referrer-Policy yang membatasi origin eksternal.

5. Checklist Pengujian Manual (Untuk Diuji di Peramban / HP)

No	Modul / Fitur	Skenario Pengujian	Kriteria Verifikasi
1	**Tampilan Responsif**	Buka portal pada resolusi 360px (Android) dan 375px (iPhone).	Tidak ada horizontal scrollbar liar; bottom navigation tidak menutupi tombol formulir.
2	**PWA Install & Offline**	Uji tombol install PWA di Chrome/Safari. Putuskan koneksi internet.	Modal instalasi muncul; halaman shell aplikasi tetap terbuka tanpa layar putih saat offline.
3	**QR & Barcode Tiket**	Buka bukti reservasi poli yang memiliki nomor antrian.	Barcode dan QR Code ter-render presisi dan dapat dipindai oleh barcode scanner fisik rumah sakit.
4	**Dekripsi & Pratinjau PDF**	Buka berkas hasil radiologi atau laboratorium terenkripsi AES-256.	PDF terdekripsi di memori dan canvas viewer dapat zoom in/out serta mengunduh berkas utuh.
5	**Notifikasi Riil Backend**	Login akun pasien riil yang memiliki jadwal kontrol aktif.	Badge counter berkurang real-time setelah dibaca; navigasi ke detail reservasi berhasil.
6	**Konektivitas Gambar Edukasi**	Akses Edukasi Kesehatan di lingkungan deployment HTTPS.	Gambar tampil tanpa mixed content warning; placeholder fallback muncul jika gambar 404.
7	**Kontrol BPJS Kosong**	Login pasien umum yang tidak memiliki rencana kontrol dokter.	Teks "Tidak ada rencana kontrol" tampil dan tombol detail tidak muncul.

6. File Test Suite & Perintah Menjalankan Ulang

Seluruh test suite otomatis telah terintegrasi di direktori `tests/` dan dapat dijalankan dengan perintah berikut:

```
# Menjalankan seluruh 140 pengujian unit & integrasi
npm run test:run

# Menjalankan pengujian dengan metrik code coverage v8
npm run test:coverage

# Memeriksa build bundle produksi
npm run build
```